

KASBAH – CELLULE 1 – TANGER – J3

PLAN DE REMÉDIATION 30 / 60 / 90 JOURS

Pôle pilote : Risque / Conformité

Priorités : à 30 jours, sécuriser les accès compromis et restaurer les services critiques depuis une source saine ; à 60 jours, durcir les accès, les sauvegardes et la continuité ; à 90 jours, renforcer durablement la détection, la gouvernance et la capacité de réponse.

Horizon	Action	Responsable	Échéance	Risque couvert	Indicateur
30 j	Fermer l'accès VPN <code>svc_oasisnet</code> , révoquer les sessions et secrets associés, puis recréer les accès prestataires avec MFA.	RSSI / DSI	J+3	R-01 – Réintrusion par accès distant compromis (A-02)	0 accès prestataire sans MFA.
30 j	Revoir les comptes privilégiés et supprimer les droits administratifs non justifiés ou devenus inutiles.	RSSI / DSI	J+7	R-01 – Accès privilégiés compromis (A-02, A-10)	100 % des comptes privilégiés revus et justifiés.
30 j	Valider l'intégrité de la copie LTO-9 de Settat et réaliser une restauration contrôlée avant toute remise en production.	DSI / Continuité	J+5	R-05 – Restauration depuis une sauvegarde compromise (A-05, A-06, A-30)	Test de restauration réussi et documenté.
30 j	Restaurer progressivement les services critiques depuis la source validée : AD, ERP et base, paie / facturation, puis partages de fichiers.	DSI / Continuité	J+10	R-04 – Indisponibilité des services critiques	Services prioritaires restaurés et fonctionnement validé.
30 j	Bloquer les règles temporaires ou non justifiées et contrôler les communications sortantes HTTPS depuis les postes et serveurs sensibles.	RSSI / Réseau	J+15	R-03 – Canal sortant et exfiltration (A-03, A-09)	Aucune règle temporaire non justifiée ; flux anormaux bloqués.
60 j	Mettre en place une revue périodique des comptes, privilèges, droits et accès prestataires.	RSSI / DSI	J+45	R-01 – Compromission des accès	Revue mensuelle documentée et écarts corrigés.
60 j	Mettre en place des sauvegardes hors ligne ou immuables, séparées du réseau de production, avec tests réguliers de restauration.	DSI / Continuité	J+50	R-05 – Sabotage ou indisponibilité des sauvegardes (A-05)	Au moins un test de restauration réussi par mois.
60 j	Renforcer la segmentation entre le SI de gestion et le réseau OT, avec filtrage strict et contrôle des flux autorisés.	RSSI / OT	J+45	R-04 – Propagation vers les systèmes industriels	Test de segmentation réalisé sans accès non autorisé vers l'OT.
60 j	Formaliser une procédure de double vérification indépendante pour les demandes financières inhabituelles ou les changements de coordonnées bancaires.	Finance / Direction	J+45	R-06 – Fraude au président / BEC (A-23)	100 % des demandes sensibles soumises à une seconde vérification.
60 j	Formaliser les règles de communication de crise avec les salariés, clients, partenaires, assureur et autorités.	Communication / Direction	J+60	R-07 – Communication tardive ou non maîtrisée	Plan validé, contacts identifiés et modèles de réponse disponibles.
90 j	Déployer une corrélation assistée par IA des événements VPN, EDR, proxy et pare-feu afin d'identifier les comportements anormaux et les séquences d'attaque.	SOC / RSSI	J+90	R-03 – Exfiltration lente non détectée (A-03)	Scénario simulé détecté et qualifié en moins d'une heure.
90 j	Réaliser un exercice de crise intégrant compromission, exfiltration, ransomware, sauvegardes et communication.	Direction / RSSI	J+75	R-01 à R-07	Exercice réalisé, écarts recensés et actions correctives décidées.
90 j	Mettre à jour les procédures de réponse à incident, de continuité et de notification à partir des enseignements de la crise MIRAGE.	Risque / Conformité	J+85	Tous les risques identifiés	Procédures mises à jour, validées et diffusées.
90 j	Effectuer une revue globale de la préparation à une nouvelle crise et intégrer les mesures correctives au plan annuel de sécurité.	Direction / RSSI / Conformité	J+90	Tous les risques identifiés	Plan annuel actualisé et responsabilités formalisées.

Défense augmentée par l'IA

L'IA sera utilisée comme outil d'assistance au SOC pour **corrélér les événements VPN, EDR, proxy et pare-feu**, prioriser les alertes et identifier plus rapidement les comportements anormaux, notamment les connexions nocturnes, les transferts inhabituels, les modifications des protections et les séquences compatibles avec une exfiltration.

Elle contribuera également au tri des alertes afin de réduire le bruit et de faciliter l'analyse des événements à forte priorité.

Limite : l'IA constitue une aide à la détection, à la corrélation et à la priorisation. Toute décision de confinement, de blocage ou de réponse reste soumise à une **validation humaine**.

Ce que nous ne referons pas

- Maintenir un accès prestataire privilégié sans MFA ni contrôle renforcé des horaires et des adresses d'origine (A-02).
- Restaurer un système depuis un point de sauvegarde sans validation préalable de son intégrité (A-05, A-30).
- Conserver une sauvegarde hors ligne pendant plusieurs semaines sans réaliser de tests périodiques de restauration (A-06).
- Maintenir des règles réseau temporaires ou des flux sortants sans journalisation ni justification (A-09).
- Attendre avant d'informer les parties compétentes lorsqu'un incident répond aux critères de notification.
- Qualifier une alerte, attribuer une attaque ou prendre une décision majeure sans recouper les éléments techniques disponibles.

Principes de suivi

Chaque action du plan est associée à un **responsable**, une **échéance**, un **risque issu de la crise MIRAGE** et un **indicateur de réussite vérifiable**.

Le plan est organisé selon trois horizons :

- **30 jours – Stopper et restaurer** : sécuriser les accès compromis, valider une source de restauration saine et remettre progressivement en service les actifs critiques.
- **60 jours – Durcir** : renforcer les accès, la segmentation, les sauvegardes, les contrôles financiers et la communication de crise.
- **90 jours – Pérenniser** : renforcer la détection, intégrer l'assistance par IA, tester la réponse à incident et mettre à jour les procédures.

Objectif : transformer les enseignements de l'incident MIRAGE en mesures correctives mesurables et vérifiables afin de réduire le risque de récurrence et d'améliorer la capacité de réponse d'AtlasGrid.